

[css] :- UT2 Question Bank.

- ✓ 1] Explain Autokey Cipher Technique with example.
- 2] Explain SQL injection attack with example.
- ✓ 3] Define Firewall and its type.
- ✓ 4] Difference betn : Virus and Worms.
- ✓ 5] Explain the RSA Algorithm with an example.
- 6] Discuss various attacks on Digital signatures. pic
- 7] Write short note: Buffer overflow. pic
- 8] What's MAC? How does it work? pic
- 9] Write short notes on:
 - a) IPsec.
 - b) Packet Sniffing. pic
 - c) ARP Spoofing. pic
- ✓ 10] Difference between SHA-1 and MD5.
- ✓ 11] Explain Kerberos protocol in detail.
- 12] Write in brief about Denial of service attack. pic

14/12/20

* Answers for Ur2 QB: —

Q7 Difference betw : Virus and Worms

Parameters	Virus	Worms
What it is?	It is a software program that can copy itself and infect the data or infection without the knowledge.	It is self-replicating spread through a network.
Need Host File	Yes (human interaction)	No (standalone)
Spread via	User action (sharing, running)	Network vulnerabilities
Speed	Slower	Very fast
Primary Goal	Damage files, disrupt systems	Consume bandwidth, exploit systems
Detection	Can be hard to detect until activated	Easy to detect due to system slowdowns
Countermeasures	Antivirus	Antivirus, Firewall
Damage Cause	Usually high	Usually medium
	Stealth virus polymorphic, metamorphic, etc.	Email worm, IRC worm, file sharing worm, etc.

Q8 Difference between: SHA-1 and MD5.

SHA-1	MD5
1. SHA stands for Secure Hash Algorithm.	1. While MD5 stands for Message Digest.
2. Presented in year 1995	2. Presented in year 1992.
3. It uses a 160-bit message digest. Hence, it is stronger against Brute-force attacks than MD5.	3. It uses a 128-bit message digest. Hence, it is weaker than SHA-1 against Brute-force attacks.
4. SHA-1 is not vulnerable against Cryptanalysis.	4. MD5 is vulnerable against cryptanalysis.
5. SHA-1 is slower than MD5	5. Faster than SHA-1
6. Uses big-endian method to represent the message.	6. Uses little-endian method to represent the message.
7. SHA has 20 rounds	7. Has 64 rounds
8. More complex	8. Simple
9. Provides balanced/tolerable security.	9. Provides indigent or poor security.
10. No serious attacks on SHA-1	10. More attacks have been reported on MD5.

Q7 Define firewall and its types.

- A firewall is a network security system that monitors and controls incoming and outgoing network traffic based on predefined security rules.
- Firewalls are network security systems that provide protect the computing resources on a trusted network from unauthorized access.

• Types of Firewalls

1) Packet filtering firewalls

- Works at the network layer.
- Checks packets based on IP address, port number, and protocol.
- Fast and Simple but less secure.
- Does not inspect actual data inside packets.

2) Stateful Inspection firewall

- Monitor the state of active connections.
- Keep track on ongoing sessions.
- More secure than packet filtering.
- Allows only valid, established connections.

3) Proxy firewall (App'l-lvl Gateway)

- Act as an intermediary bet user and internet.
- Hide Internal IP address.
- Provide high security but may slowdown performance.

4) Next-generation firewall (NGFW)

- Adv. firewall with additional features.
- Includes intrusion detection/prevention, deep packet inspection, and application awareness.
- Can block modern threats like Malware & Ransomware.

5) Hardware firewall

- Phy. device placed bet network and gateway.
- Protects Entire network.
- Commonly used in organization.

6) Software firewall

- Installed on individual computers or devices.
- Protect single system.
eg., Windows Firewall.

Q8 Explain Autokey cipher Technique with example.

- Autokey cipher is a polyalphabetic substitution cipher where the key extends itself using the plaintext.
- It fixes the main weakness of Vignere: repeating keys. Instead of repeating, you "auto" generate more key letters from the message itself.

• How it works

1. Choose a primer key: a short keyword to start.
2. Extend the key: Append plaintext to primer to make the full key as long as the msg.
3. Encrypt: For each letter, add the key letter to the plaintext letter mod 26.

• Example :-

Encryption Process:

Plaintext:

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	
P	L	A	I	N	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S	A
K	P	L	A	I	N	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S
C	P	L	A	I	N	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S
E	P	L	A	I	N	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S	A	N	C	E	S	S

• Example:-

I) Encryption Process

Plain text: HELLO

keyword: KEY

Step 1: Extend the key

Append plain text after the keyword.

Plaintext	H	E	L	L	O
key	K	E	Y	H	E

Step 2: Convert letters to no's.

A=0; B=1; Z=25

letter	Value	a	b	c	d	e
H	7	0	1	2	3	4
E	4	f	g	h	i	j
L	11	5	6	7	8	9
O	14	k	l	m	n	o
K	10	10	11	12	13	14
Y	24	p	q	r	s	t
		15	16	17	18	19
		u	v	w	x	y
		20	21	22	23	24
		z				
		25				

Steps: Apply Encryption formula

$$C = (P_i + K_i) \bmod 26$$

(P) Plaintext	key (K)	Calculation	(C) Cipher Text
H(7)	K(10)	$7+10=17$	R
E(4)	E(4)	$4+4=8$	I
L(11)	Y(24)	$11+24=35$ $\bmod 26=9$	J
L(11)	H(7)	$11+7=18$	S
O(14)	E(4)	$14+4=18$	S

II) Decryption Process

Step 1:- Apply Decryption formula

$$P = (C_i - K_i) \bmod 26$$

Ciphertext (C_i) Key (K_i) Calculation (P) Plaintext

R(18)	K(10)	$18-10=8$	H
I(8)	E(4)	$8-4=4$	E
J(9)	Y(24)	$9-24=-15$ $\bmod 26=11$	L

S(18)	H(7)	$18-7=11$	L
S(18)	E(4)	$18-4=14$	O

-15 mod 26.

Remember:
Substitute Q=-1

$$-1 = -26 + R \Rightarrow R = -26 + 1 = -25$$

$$-25 + 26 = 1$$

$$R = 1$$

$$= 11$$

Q] Explain kerberos protocol in detail.

- Microsoft introduced Kerberos in Window 2000 Server as a default authentication protocol.
- Kerberos is also called as Authentication protocols that use the concept of "tickets" as a token to prove the identity of user over a non-secure network.
- To accomplish the task of Secure authentication kerberos uses a trusted third-party is called a Key Distribution Center (KDC).
- The Key Distribution Center uses two- techniques for authentication:-

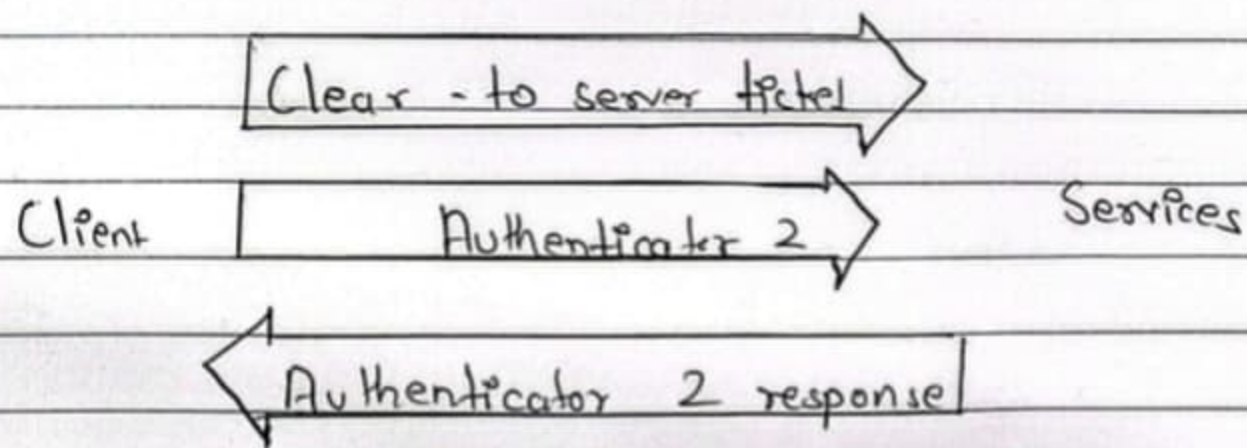
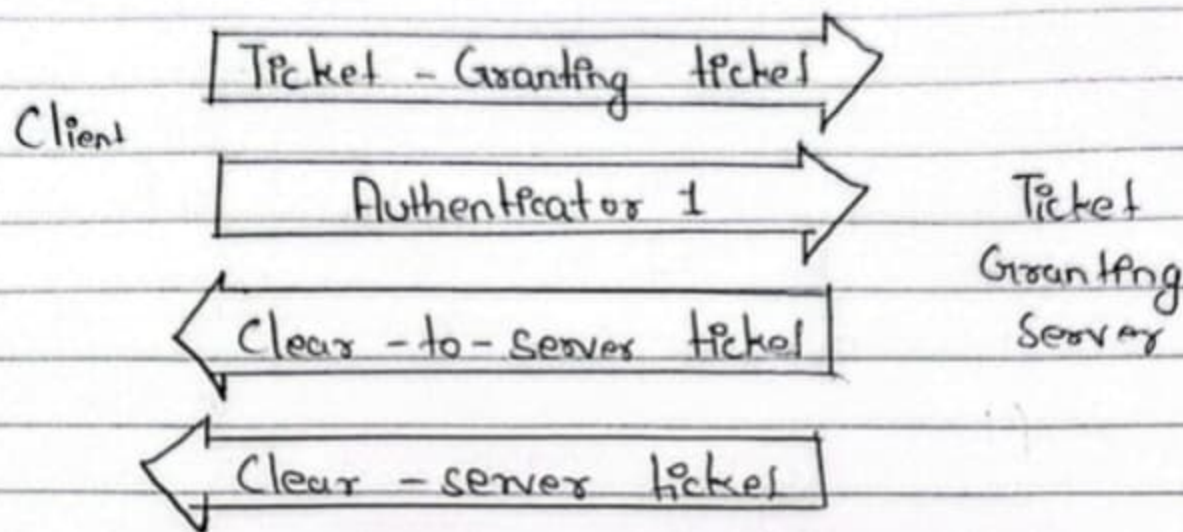
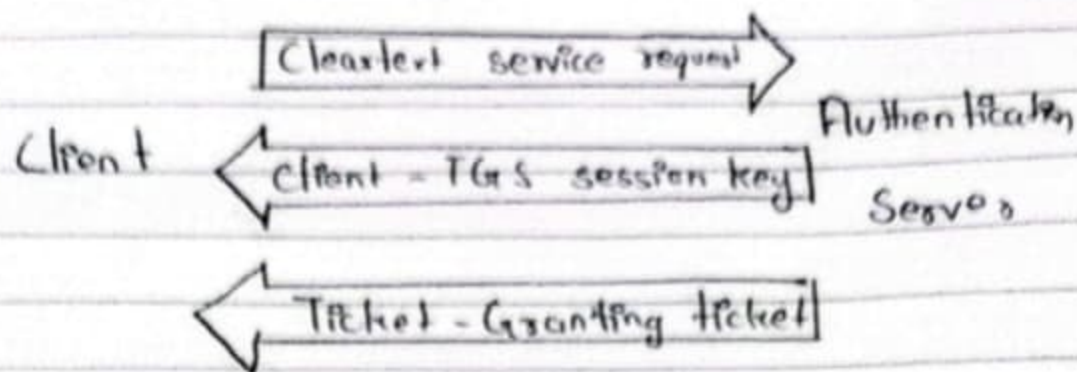
1) Authentication Server (AS):

- performs user authentication
- provides Ticket Granting Ticket (TGT)

2) Ticket Granting Server (TGS):

- which permits/grants tickets to user.

- The Role of an Authentication Server (AS) is to store a dB like a secret key of the user & its services. The secret key of a user is generated using one way hash of user provided password.
- Main aim to provide Centralize authentication of entire n/w.
- This phase is called as Authentication Phase bcz during this phase only Authentication can be done betⁿ Authentication Server, Ticket Granting Server & Service provider.
- As shown in fig, first Client and Authentication themselves & authenticate themselves to each other.
- Client & TGS authenticate themselves. finally Client & Request Service Provider authenticate themselves to each other regarding which info/service client wants.



Kerberos authentication process

Q8 Discuss various attacks on Digital signatures

Ans 1) Chosen - message attack

The chosen attack can be of two type
a) Generic chosen - method:- In this type of attack the attacker tricks the genuine user into digitally signing a message that the user does not normally intend to sign. As a result the attacker tries to create a new message that he wants a genuine user to sign and uses the previous signature.

b) Direct chosen - method:- In this attack attacker has the knowledge about sender public key and obtain his signature on the message. The attacker
• the replace

2) Known - Message attack

i) In this type of attack the attacker obtains some message that the sender has sent and a key to create a new false message.

ii) Now he tries to the signature of sender on to the document that sender does not intend to sign by using the method.

3) Key - Only attack

i) In key only attack the public key of sender is available to everyone and attacker tries to misuse this public information.

ii) The attacker tries to recreate the signature of the sender and digitally sign the document or message that the sender does not intend to sign. This would cause a great threat to authentication of the message which is not acceptable as the sender cannot deny signing it.

Q9) Write short note on

» Packet Sniffing

- Ans
- 1) Packet sniffing is done by using tools called packet sniffers. It can be either filtered or unfiltered.
 - 2) Filtered sniffing is used when only specific data packets have to be captured and unfiltered sniffing is used when all the packets have to be captured. Wireshark and Smart Sniff are examples of packet sniffing tools.
 - 3) A hardware packet sniffer is designed to be plugged into a network, and to examine it. A hardware packet sniffer is particularly useful when attempting to see traffic of a specific network segment.
 - 4) A software packet sniffer changes its configuration so that the network interface passes all network traffic up the stack. This configuration is known as promiscuous mode.
 - 5) Defense: Encrypt the data you send or receive. Use trusted Wi-Fi networks and scan your network for danger or issues.

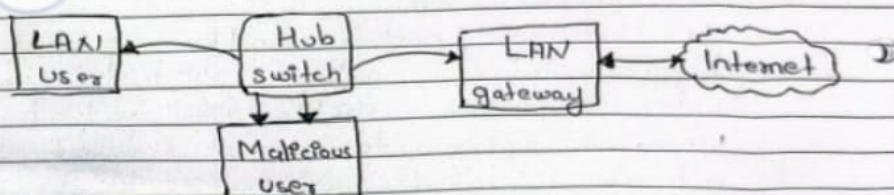
FOR EDUCATIONAL USE

FOR EDUCATIONAL USE

CS CamScanner

2) ARP Spoofing

- 1) ARP spoofing is a type of attack in which a malicious actor sends falsified ARP (Address Resolution Protocol) message over a local area network.
- 2) This results in the linking of an attacker's MAC address with the IP address of a legitimate computer or server on the network.
- 3) Once the attacker's MAC address is connected to an authentic IP address, the attacker will begin receiving any data that is intended for that IP address.
- 4) ARP spoofing can enable malicious parties to intercept, modify, or even stop data in transit.
- 5) ARP spoofing attack can only occur on local area networks that utilize the Address Resolution Protocol.



ARP Spoofing

- 5) Defense:- Filter or prevent potentially falsified IP addresses using packet filtering. ARP spoofing detection software also helps prevent these attacks. Secure communication methods can also be used.

Q.11.1.1 What is a Denial of service attack? What are the different ways in which an attacker can mount a DOS attack on a system?

(Ref. sec. 11.1.1)

Dec. 15, May 17, 10/3 Marks

Q.11.1.2 Write in brief about Denial of service attacks.

(Ref. sec. 11.1.1)

May 16, 5 Marks

Q.11.1.3 Explain briefly with example, How the following Denial of service attacks occurs.

(Ref. sec. 11.1.1)

Dec. 16, Dec. 17, 5 Marks

- In this attack, the attacker keeps on sending or makes the network or bandwidth overflow by e-mails or spam mail by depriving the victim to access services.
- It is a continuous effort of attackers to make victim unable to use any internet service or resources.

Scanned by CamScanner



- The attacker's main target for websites or services which include financial site bank site or credit card gateway systems.
- The targeted network which are root for DOS are mobile phone network or credit card gateway network.
- Buffer overflow technique is used to make denial service attack. What an attackers does is it takes packet (where is a unit of data) divide into small chunks, the attacker checks for the IP address of the particular network in that packet and floods the network of victim with repeated request. As IP is a fake, from attacker's machine.
- This acts consumes bandwidth which let other service to fail or unavailable for other user.

A DOS attack does following actions

1. Flood whole network with unnecessary traffic.
2. Damage connection between two systems so that communication cannot occur.
3. Disrupt services to legitimate users.
4. Prevents individuals to access network services.

11.1.1(A) Classification of Attacks

(1) Bandwidth attack

- Every website is given particular amount of bandwidth to host (e.g. 50 GB) loading of any websites takes certain amount of time to display whole webpage.
- If more visitors load particular websites page or consumes whole 50 GB bandwidth than particular websites can be ban.
- The attacker does the same by opening 100 pages of site and keeps on loading and refreshing, consuming all bandwidths to make the site out of services.

(2) Logic attack

Attack on the network software to make it vulnerable.

For example : in TCP/IP stack.

(3) Protocol attacks

This attack, consumes more amount of resources in victims system. It is an attack on particular features of some protocol that are been installed in the victims systems.

2. **Known-Message Attack:** The attacker has a set of previous messages and their valid signatures. They use this to try and forge a signature for a new message.
3. **Chosen-Message Attack:** The attacker picks specific messages and tricks the sender into signing them. This helps the attacker find patterns in the private key.
4. **Forgery Attack:**
 - **Existential Forgery:** The attacker creates a valid signature for a random, meaningless message.
 - **Selective Forgery:** The attacker creates a valid signature for a specific message they want to send.

Q7. Write short notes on Buffer Overflow.

Answer: A **Buffer Overflow** occurs when a program tries to write more data into a fixed-length block of memory (a buffer) than it is designed to hold.

- **How it works:** The extra data "overflows" into adjacent memory space, overwriting existing data or instructions.
- **Impact:** This can cause the program to crash or, more dangerously, allow an attacker to inject and execute their own malicious code (like opening a back door).
- **Prevention:** Developers can prevent this by using modern programming languages that manage memory automatically or by performing strict "bounds checking" on all user inputs.

Q8. What is MAC? How does it work?

Answer:

MAC (Message Authentication Code) is a short piece of information used to verify that a message is authentic and has not been changed during transmission.

How it works:

1. **Input:** The sender takes the message and a **secret key** (shared only between sender and receiver).
2. **Calculation:** A MAC algorithm (like HMAC) processes the message and the key to produce a unique code (the MAC).
3. **Transmission:** The sender sends the message and the MAC to the receiver.
4. **Verification:** The receiver uses the same key and message to calculate their own MAC. If the receiver's MAC matches the one sent, the message is trusted.

Q9. Write a short note on IPSec, Packet Sniffing, and ARP spoofing.

Answer:

- **IPSec (Internet Protocol Security):** A suite of protocols used to secure communication at the network layer. It provides encryption and authentication for data sent over IP networks (often used in VPNs).
- **Packet Sniffing:** The process of capturing and monitoring data packets as they travel across a network using software (like Wireshark). It can be used for network troubleshooting or by attackers to steal sensitive info like passwords.
- **ARP Spoofing:** A technique where an attacker sends fake ARP (Address Resolution Protocol) messages onto a local network. This links the attacker's MAC address with the IP address of a legitimate server, allowing the attacker to intercept or modify traffic.

Q10. Difference between SHA-1 and MD5.

Answer: Both are "Hash Functions" used to create a digital fingerprint of data, but they differ in security.